

GDPR-DPDP DUAL COMPLIANCE ASSESSMENT

A Comparative Privacy Compliance Analysis
under the GDPR and India's DPDP Act, 2023



EuroBridge Technologies Pvt. Ltd.

HR & Payroll SaaS Solutions
Connecting People. Complying with Privacy.



PORTFOLIO PROJECT 1

Certified Data Protection Officer (CDPO) Portfolio Project



PREPARED BY
Nikita Michael

FCRF Academy – CDPO Certification Program



JULY 2026



GDPR

EUROPEAN UNION
GENERAL DATA PROTECTION
REGULATION



DPDP ACT, 2023

DIGITAL PERSONAL DATA
PROTECTION ACT, 2023
INDIA



PRIVACY BY DESIGN



ACCOUNTABILITY



TRANSPARENCY



GLOBAL COMPLIANCE

GDPR–DPDP Dual Compliance Assessment

A Learning-Based Privacy Compliance Portfolio Project

Prepared as part of the CDPO exam preparation and portfolio building

Executive Summary

EuroBridge Technologies Pvt. Ltd. is a fictional SaaS company headquartered in Bengaluru, India, providing HR and payroll software to clients in both India and the European Union. Because the company has an active sales office in Germany and processes personal data of EU-based employees and customers, it falls under the territorial scope of the **General Data Protection Regulation (GDPR)**. At the same time, because it is an Indian entity processing personal data of individuals in India (and handling data digitally), it is also subject to India's **Digital Personal Data Protection Act, 2023 (DPDP Act)**.

This assessment is written as a self-study exercise to practice reading a business scenario the way a privacy professional would, identifying data flows, mapping legal obligations, spotting gaps, and prioritising fixes. It is not a legal opinion, and none of the conclusions here should be treated as authoritative legal advice. I attempt to reason through a realistic dual-jurisdiction scenario using what I have learned about both laws so far.

Key observations:

- EuroBridge processes a wide variety of personal data (employee, applicant, customer, marketing, vendor, and website visitor data), which means it wears different hats — data controller in some activities, data processor in others.
- GDPR's consent, lawful basis, and rights framework are more granular than the DPDP Act's, which relies more heavily on consent and "certain legitimate uses."
- The DPDP Act introduces some concepts with no close GDPR equivalent, such as **Consent Managers** and **Nominee rights**.
- Overall compliance status (fictional, for this exercise): **Partially compliant**, with several documentation and process gaps typical of a fast-growing SaaS company that has not yet formalised its privacy programme.

1. Organisation Overview

Business model: EuroBridge Technologies Pvt. Ltd. builds and sells a cloud-based HR and Payroll SaaS platform used by mid-sized businesses to manage recruitment, employee records, payroll processing, and benefits administration.

Services: Applicant tracking, employee onboarding, payroll calculation and disbursement, leave and attendance management, and basic HR analytics dashboards.

Customers: Small and mid-sized businesses in India and the EU (primarily Germany, with a growing base in France and the Netherlands).

Types of personal data processed:

- Employee data (of EuroBridge's own staff): contact details, salary, bank details, performance records
- Customer data (client company HR admins): names, work emails, login credentials
- End-user data (client company's employees, processed on behalf of clients): payroll data, ID numbers, bank details, attendance records
- Applicant data: resumes, interview notes, background verification results
- Marketing data: email addresses, website form submissions
- Vendor data: contact and billing details of third-party vendors
- Website visitor data: cookies, IP addresses, analytics identifiers

Data subjects: Employees, job applicants, customer HR administrators, end-users of client companies, vendors, and website visitors.

Third-party vendors: Cloud hosting provider (AWS, EU and India regions), email marketing tool, background verification agency, payment gateway for payroll disbursement, customer support ticketing tool.

Cloud services: Primary infrastructure hosted on AWS, with data residency split between an India region (for Indian customer data) and an EU region (for EU customer data), though, as explored later, this separation is not fully enforced in practice.

Data flows: Data flows from client HR admins into the platform, through internal processing (payroll calculations, analytics), out to vendors (background checks, payment processing), and occasionally between the Bengaluru/Pune engineering teams and the Germany sales office for support purposes.

2. Why Both Laws Apply

GDPR territorial scope: Under Article 3, GDPR applies to organisations established in the EU, but also to organisations outside the EU that offer goods or services to individuals in the EU or monitor their behaviour. EuroBridge has an active sales office in Germany and actively markets its product to EU businesses, which brings it squarely within GDPR's **extraterritorial scope** even though the company itself is based in India.

DPDP applicability: The DPDP Act, 2023, applies to the processing of digital personal data within India, and also to processing outside India if it relates to offering goods or services to individuals in India. Since EuroBridge processes personal data of Indian employees, applicants, and customers digitally, DPDP clearly applies to a large share of its operations.

Data Controller vs Data Fiduciary: GDPR uses the term "controller" for the entity that decides the purpose and means of processing, and "processor" for an entity processing data on the controller's behalf. DPDP uses "Data Fiduciary" (roughly equivalent to controller) and "Data Processor" (same term, similar meaning). For EuroBridge:

- When processing its own employees' data → it is a controller/fiduciary.
- When processing client companies' employee data on their behalf (payroll processing) → it is typically a processor under GDPR and a Data Processor under DPDP, with the client company being the controller/fiduciary.

DPO requirements: GDPR requires a Data Protection Officer where core activities involve large-scale, systematic monitoring, or large-scale processing of special category data (Article 37). DPDP requires a **Data Protection Officer** only for entities classified as **Significant Data Fiduciaries**, a category the government will notify based on volume and sensitivity of data processed, among other factors. EuroBridge likely qualifies for a GDPR DPO given the scale of EU HR data processed, and may eventually be notified as a Significant Data Fiduciary under DPDP given its payroll data volumes, though this determination rests with the government.

3. Comparative Compliance Assessment

Processing Activity	Purpose	Personal Data Processed	GDPR Lawful Basis	DPDP Legal Ground	Rights Under GDPR	Rights Under DPDP	Cross,Border Transfer Considerations	Compliance Risks	My Observations
Recruitment	Hiring for internal roles	Resume, contact info, interview notes	Legitimate interest / pre,contractual steps	Consent	Access, erasure, rectification	Access, correction, erasure	Minimal — mostly domestic	Retaining rejected applicant data too long	Both laws expect a clear retention limit; DPDP is stricter about needing purpose,linked deletion
Payroll processing	Paying employees and client end,users	Bank details, salary, tax IDs	Contractual necessity / legal obligation	Legal obligation / contract performance	Access, rectification	Access, correction	High — client data may cross India,EU boundary	Vendor sub,processing without clear agreements	This is the highest,risk activity given the sensitivity of financial data
Customer onboarding	Setting up new client accounts	Business contact details, admin credentials	Contract	Contract performance / consent	Access, portability	Access, correction	Low to moderate	Weak onboarding data minimization	Easy to over,collect "just in case" fields here
Marketing emails	Promoting product features	Email address, name, company	Consent (opt,in)	Consent	Withdraw consent, objection	Withdraw consent, grievance	Low	No unified unsubscribe/ consent record	GDPR's opt,in consent standard is stricter than typical Indian practice
Cookies	Website functionality and analytics	Cookie ID, IP address, browsing behavior	Consent (for non,essential cookies)	Consent	Objection, withdraw consent	Withdraw consent	Low	Cookie banner does not distinguish essential vs non,essential	A common gap — many Indian SaaS sites use "accept all" banners not compliant with GDPR granularity

Website analytics	Understanding site usage	IP address, device data, usage patterns	Legitimate interest / consent	Consent (if personal data)	Objection	Withdraw consent	Depends on analytics vendor location	Using EU restricted analytics tools without safeguards	Needs a clear legal basis assessment per tool used
Customer support	Resolving client issues	Contact details, ticket content	Contract / legitimate interest	Contract performance	Access, rectification	Access, correction	Moderate — support tool may be hosted abroad	Support tickets containing sensitive data with no access controls	Support agents often see more data than needed — minimization gap
Vendor management	Managing background check, hosting vendors	Vendor contact and billing info	Contract / legitimate interest	Contract performance	Access	Access, correction	Depends on vendor location	No standard Data Processing Agreement (DPA) template	Both laws expect written processor obligations — this is foundational and often missing early on
CCTV (office premises)	Physical security	Employee/visitor images	Legitimate interest	Legitimate/certain uses	Access (limited), objection	Access (limited)	None expected	No signage or retention policy	DPDP's "certain legitimate uses" concept could apply here, though this needs further reading on my part
Background verification	Pre,employment checks	ID documents, criminal record checks (via vendor)	Consent / legal obligation	Consent	Access, erasure	Access, correction, erasure	Moderate — depends on vendor location	Verification agency retains data beyond need	Special category data under GDPR requires extra safeguards; DPDP treats this less granularly

Note: This table reflects my current understanding and is simplified for portfolio purposes; a real assessment would require legal review and a full Record of Processing Activities (RoPA).

4. Individual Rights Comparison

Right	GDPR	DPDP	My Notes
Access	Yes, detailed (Art. 15)	Yes, but less prescriptive	GDPR specifies more information must be provided (e.g., recipients, retention period)
Correction	Yes	Yes	Broadly similar
Erasure	Yes, with specific conditions (Art. 17)	Yes, but conditions less detailed	DPDP erasure right is present but the Act gives fewer specifics on exceptions
Data Portability	Yes (Art. 20)	Not explicitly provided	A clear gap — DPDP does not currently guarantee portability
Restriction of Processing	Yes (Art. 18)	Not explicitly provided	Another notable gap in DPDP
Objection	Yes (Art. 21)	Limited (mainly via consent withdrawal)	GDPR gives a standalone objection right; DPDP relies more on consent withdrawal
Withdraw Consent	Yes	Yes	Both require it to be as easy as giving consent
Grievance Redressal	Via supervisory authority complaint	Yes, explicit grievance mechanism required	DPDP requires fiduciaries to have a grievance redressal system — a more operational requirement
Nominee Rights	Not present	Yes — unique to DPDP	Allows a person to nominate someone to exercise their rights in case of death or incapacity
Automated Decision-Making	Yes, explicit right (Art. 22)	Not explicitly addressed	Another area where GDPR is more protective

Reflection: Working through this table, GDPR appears to offer a broader and more explicit set of individual rights — particularly portability, restriction, objection, and protections around automated decision-making. DPDP's rights framework feels more streamlined, likely reflecting its more consent-centric and simplified approach. However, DPDP's grievance redressal and nominee rights are practical additions that GDPR does not have in the same form, and I found those genuinely interesting since they address real-world situations (like data belonging to a deceased person) that GDPR does not directly cover.

5. Cross-Border Data Transfers

EU to India transfers: Since India does not currently have a GDPR adequacy decision, EuroBridge's Germany office transferring EU personal data to Bengaluru/Pune for processing would need an additional safeguard, most commonly **Standard Contractual Clauses (SCCs)**, to lawfully transfer that data outside the EEA.

India to EU transfers: DPDP takes a different approach; rather than requiring safeguards for every transfer, it allows transfers to any country **except** those specifically restricted (blacklisted) by the Indian government via notification. As of this writing, the government has not published such a restricted list, which in practice makes DPDP's transfer regime comparatively simpler for outbound data from India.

Standard Contractual Clauses (SCCs): These are already approved contract clauses issued by the European Commission that EU exporters and non-EU importers sign to create enforceable data protection commitments when no adequacy decision exists.

Adequacy decisions: The European Commission can declare that a non-EU country provides an "adequate" level of protection, allowing free data flow without extra safeguards. India does not currently have this status.

Practical challenges: EuroBridge would need to implement SCCs (or another approved mechanism) for its Germany-to-India data flows, maintain records of these transfers, and separately track its India-to-EU flows under the simpler DPDP regime, meaning two different transfer compliance tracks running in parallel.

What I learned: Before this exercise, I assumed both laws treated cross-border transfers similarly. Comparing them side by side made it clear that GDPR's transfer regime is adequacy/safeguard-driven, while DPDP's is closer to a "blacklist" model. This distinction changes how a compliance team would prioritise its work, GDPR transfers need proactive paperwork (SCCs) regardless of destination, while DPDP transfers are only restricted once the government acts.

6. Gap Analysis

#	Requirement	Current Status	Gap Identified	Recommendation	Priority
1	Record of Processing Activities (RoPA)	Not maintained	No central inventory of processing activities	Build and maintain a RoPA covering all data flows	High

2	Data Processing Agreements with vendors	Ad hoc, informal	No standard DPA template	Draft a standard DPA and execute with all vendors	High
3	Cookie consent banner	Present but not granular	Does not separate essential/non,essential cookies	Implement a granular consent management platform	High
4	Privacy notices	Generic, single notice	Not tailored to each data subject category	Create separate notices for employees, customers, applicants	Medium
5	Data retention policy	Undefined	No documented retention periods	Define and enforce retention schedules per data category	High
6	Cross,border transfer mechanism (EU,India)	Not implemented	No SCCs signed with Indian entity	Execute intra,group SCCs	High
7	DPO appointment	Not appointed	Unclear whether GDPR threshold is met	Conduct assessment and appoint DPO if required	Medium
8	Data Protection Impact Assessments (DPIA)	Never conducted	High,risk processing (background checks) lacks DPIA	Conduct DPIAs for high,risk activities	Medium
9	Consent Manager registration (DPDP)	Not applicable yet	Not using a registered Consent Manager	Evaluate need once DPDP rules are fully notified	Low
10	Grievance redressal mechanism	Informal, via email	No documented process or timelines	Formalize grievance process with defined timelines	High
11	Data breach response plan	Draft exists, untested	Not tested via simulation	Run a tabletop breach simulation exercise	Medium
12	Employee privacy training	One,time onboarding session only	No refresher training	Introduce annual privacy refresher training	Medium
13	Access controls on support tools	Broad access for all agents	No role,based access control	Implement role,based access restrictions	High
14	Vendor risk assessment	Not performed	Vendors onboarded without privacy due diligence	Introduce vendor privacy risk questionnaire	Medium
15	CCTV signage and policy	Cameras installed, no signage	No documented purpose or retention limit	Add signage and define retention period	Low
16	Data subject request handling process	Handled manually, inconsistent	No SLA or tracking system	Implement a formal DSR intake and tracking process	High
17	Special category data safeguards	Minimal extra controls	Background check data lacks additional safeguards	Apply enhanced encryption and access limits	Medium

7. Risk Assessment

Risk	Likelihood	Impact	Suggested Mitigation
Unauthorized cross,border transfer without SCCs	Medium	High	Execute SCCs and document transfer mechanism
Data breach via support tool with excessive access	Medium	High	Implement role,based access control and audit logs
Regulatory penalty for non,compliant cookie consent	Medium	Medium	Deploy compliant consent management platform
Vendor mishandling background check data	Low	High	Conduct vendor due diligence and sign DPAs
Failure to respond to data subject requests in time	Medium	Medium	Set up a DSR tracking system with defined SLAs
Retaining applicant data indefinitely	High	Low to Medium	Define and automate retention/deletion schedule
Lack of DPO where legally required	Low to Medium	Medium	Complete threshold assessment and appoint DPO if needed

8. Enforcement Comparison

Aspect	GDPR	DPDP
Supervisory Authorities	Independent Data Protection Authorities per EU member state (e.g., Germany's BfDI/state DPAs)	Data Protection Board of India (a centralized body)
Penalties	Up to €20 million or 4% of global annual turnover, whichever is higher	Up to ₹250 crore per instance, depending on the nature of the breach
Enforcement Mechanisms	Investigations, audits, corrective orders, fines, and possible processing bans	Inquiries, orders, and monetary penalties by the Data Protection Board
Business Consequences	Reputational damage, operational restrictions, potential litigation from data subjects	Financial penalties, reputational impact, and possible directions to stop processing

Observation: GDPR's enforcement is decentralised across national authorities, which can lead to some variation in interpretation across EU member states. DPDP centralises enforcement through a single Data Protection Board, which may lead to more consistent (though still developing) enforcement practices in India.

9. Compliance Roadmap

Immediate (0–3 months):

- Build an initial RoPA covering major processing activities
- Draft and begin executing a standard Data Processing Agreement with vendors
- Implement a compliant, granular cookie consent banner
- Set up a basic data subject request intake process

Medium Term (3–6 months):

- Conduct a DPO threshold assessment under GDPR and DPDP
- Run DPIAs on high-risk activities (background verification, payroll)
- Define and implement data retention schedules
- Introduce role-based access controls for support and HR tools

Long Term (6–12 months):

- Formalise an annual privacy training programme
- Conduct an internal privacy audit against both GDPR and DPDP requirements
- Explore ISO/IEC 27701 alignment for a structured privacy information management system
- Test the incident response plan through a simulated breach exercise

10. Personal Reflection

Working through this project helped me see the real difference between *reading about* a privacy law and *applying* it to a messy, realistic business scenario. It's one thing to know that GDPR has six lawful bases for processing, and another to sit down and decide which basis applies to a specific activity like background verification, where consent, legal obligation, and legitimate interest could all plausibly apply depending on the details.

The most challenging part was comparing individual rights across the two laws. GDPR's rights are well-documented with over a decade of guidance and case law behind them. At the same time, DPDP is newer and some of its practical mechanics, like how Consent Managers will actually function, or what "certain legitimate uses" will cover in practice, are still being clarified through rules and guidance. I had to be careful not to assume DPDP works exactly like GDPR just because the concepts sound similar; several times, I found that a term meant something narrower or broader than I initially assumed.

Building the gap analysis and risk register was the most useful part of the exercise for me. It forced me to think less like someone memorising statutes and more like someone who has to prioritise a real backlog of work — deciding what's genuinely high-risk (like cross-border payroll transfers) versus what's lower priority (like CCTV signage). That prioritisation instinct is something I don't think you can learn from reading the text of a law alone.

This project also showed me how much I still have to learn. I want to go deeper into **Data Protection Impact Assessments (DPIAs)**, especially how to structure one for a company like EuroBridge with several high-risk processing activities. I'm also curious about **ISO/IEC 27701** as a way to operationalise privacy management alongside a broader ISMS, and I want to get more hands-on practice building a proper **Record of Processing Activities (RoPA)**, since that seemed to be the foundation that almost everything else in this assessment depended on. Longer term, I'd like to shadow or study real privacy audits to see how gap analyses like this one translate into actual remediation projects.

Overall, this exercise made both laws feel less like abstract legal text and more like a practical toolkit: one I'm still learning to use, but one I'm genuinely enjoying getting familiar with.

This is a fictional case study created for educational and portfolio purposes as part of ongoing CDPO exam preparation. It does not represent an actual company, a real compliance engagement, or legal advice.